# Relatório LGPD — RoPA + RIPD + Mapa de Suboperações

> **CONFIDENCIAL — USO INTERNO CASTRO INTELLIGENCE / ASSESSORIA JURÍDICA.** Este documento contém diagnóstico honesto, gaps de conformidade e plano de adequação com referências a `arquivo:linha`. **Não compartilhar com cliente.** Para o cliente controlador, usar `LGPD_RoPA_RIPD_CLIENTE.md`.

- **Produto:** Castro Intelligence CRM (SaaS multi-tenant de atendimento via WhatsApp Business Platform)
- **Papel da Castro neste documento: Operador (processador)** — art. 5º VII da LGPD
- **Versão:** 1.1 — adendo do refactor Lead/Atendimento (Fases 1-5A)
- **Data:** 2026-05-28 (atualização) · 2026-05-15 (diagnóstico inicial)
- **Autores:** Rafa + Claude (análise técnica)
- **Base legal do produto:** Lei nº 13.709/2018 (LGPD)
- **Relacionado:** CLAUDE.md §2, ADR 0001, ADR 0002, ADR 0003

> **Adendo 2026-05-28:** o refactor `PLANO_LEAD_ATENDIMENTO_E_REGRAS` (Fases 1-5A — ver ADR 0003 + dailies em `docs/internal/`) introduziu novos campos e operações de tratamento. Os pontos em §1.3 e as operações 11-14 em §1.4 abaixo refletem o estado atualizado. Não houve nova categoria de **titular** nem novo **suboperador**.

> **Status em 2026-08-21 — o que este diagnóstico já não descreve:**
>
> - **Residência dos dados:** a produção migrou para `us-west1` (Oregon, **EUA**) no cutover de 2026-06-10. Toda menção a `southamerica-east1`, "dados no Brasil" e ao projeto `project-26fb9c99-8ee9-4179-aef` (§0, §2.5, §3.1, §3.2, §3.4 e os diagramas) descreve o ambiente **ANTIGO de São Paulo**. A residência definitiva é decisão em aberto (J10 de `../PLANO_J3_LGPD_E_REVOGACAO.md`); R-12 (região do bucket de mídia) precisa ser reverificado no projeto novo.
> - **Marco bloqueante ultrapassado pelos fatos:** a §2.7 condiciona onboardar clínica ao fechamento de R-10/R-6, mas o tenant `varizemed` está **em produção com dado de saúde desde 2026-07-29** — J-3 deixou de ser gate pré-go-live e virou remediação viva (`../PLANO_J3_LGPD_E_REVOGACAO.md`, ainda **não implementado**).
> - **R-6 (rules):** as rules por tenant já estão em prod — `firestore.rules` isola contato/conversa em `canSeeContactScoped` (atribuído a si ou pool sem dono, nunca por departamento). Continua aberto o recorte de `wa_messages`, cuja leitura segue ampla dentro do tenant (F4 do J-3, decisão J5).
> - **R-13 (consentimento):** tenants com agente de IA ganharam gate LGPD com prova no contato (`lgpd_consent`, `lgpd_consent_at`, `lgpd_policy_version` — `lgpd_bot.py` / `bot_service.py`). A **revogação (D8) ainda não existe** no código.
> - **R-7, R-8, R-9, R-10 seguem abertos**; R-11 segue pendência jurídica. Estado atual das decisões arquiteturais: ADRs 0007-0011 em `../decisions/`.

---

## 0. Sumário executivo

O Castro Intelligence CRM processa dados pessoais de **clientes finais** (leads/contatos via WhatsApp) e de **operadores** das empresas-clientes, potencialmente **sensíveis** quando o tenant é uma clínica médica (`CLAUDE.md §1/§2`).

Na cadeia LGPD:

```
Titular (cliente final / operador)
   │
   ▼
CONTROLADOR  = cliente B2B (ex.: HUBLOC) — define finalidade, é dono da WABA
   │  (relação contratual / DPA)
   ▼
OPERADOR     = CASTRO INTELLIGENCE DATA ML LTDA (este produto)
   │  (suboperação)
   ▼
SUBOPERADORES = Google LLC (GCP/Firebase) · Meta Platforms Inc. (WhatsApp)
```

**Pontos fortes já implementados:** isolamento multi-tenant estrutural por subcoleção, validação HMAC de webhook, Firebase Auth com gate de e-mail/domínio, `audit_log` de mutações com IP, utilitários de redação de PII, dados primários hospedados no Brasil (`southamerica-east1`), auditoria de campo duplo (`channel_owner_user_id` vs `sender_user_id`).

**Principais gaps (detalhados na §6):** ausência de endpoints de direitos do titular (art. 18), ausência de política formal de retenção/expurgo, Firestore rules permissivas em produção, DPA/garantias de transferência internacional não verificados com Meta e Google, audit de leitura passiva incompleto, criptografia de campo ausente para cenário de dados sensíveis.

**Conclusão:** a arquitetura é defensável e demonstra *intenção* de conformidade (diretriz obrigatória no `CLAUDE.md §2`, ADRs registrando riscos), mas a *implementação dos direitos do titular e da governança de retenção/transferência internacional está incompleta*. O plano de adequação na §7 prioriza o fechamento por gravidade × esforço.

---

# PARTE 1 — RoPA (Registro de Operações de Tratamento)

> Art. 37 da LGPD: controlador e operador devem manter registro das operações de tratamento. O quadro abaixo é o registro da Castro Intelligence **enquanto operadora**, executando tratamento por conta e ordem do controlador (cliente B2B).

## 1.1 Agentes de tratamento

| Papel | Identificação |
|---|---|
| **Controlador** | Cliente B2B (ex.: HUBLOC) — razão social, CNPJ e encarregado do cliente: `[CONTROLADOR_RAZAO_SOCIAL]` / `[CONTROLADOR_CNPJ]` / `[ENCARREGADO_CLIENTE]`. É dono da WABA e define finalidades. |
| **Operador** | CASTRO INTELLIGENCE DATA ML LTDA — CNPJ 63.609.610/0001-07, Brasil. Tech Provider verificado pela Meta (Business ID `877897608035564`, App ID `1434723791183375`). |
| **Suboperador 1** | Google LLC — GCP (Cloud Run, Cloud Storage, Secret Manager, Cloud Logging) + Firebase (Firestore, Firebase Auth). |
| **Suboperador 2** | Meta Platforms, Inc. — WhatsApp Business Platform / Graph API. |
| **Suboperador 3 (condicional)** | Google Workspace / Google Chat — somente se `FEATURE_GOOGLE_CHAT` habilitado (comunicação interna de operadores). |
| **Encarregado (DPO) Castro** | `[ENCARREGADO_CASTRO]` — nome, e-mail e canal de contato a definir e publicar. |

## 1.2 Categorias de titulares

1. **Clientes finais / leads** — pessoas que entram em contato com a empresa-cliente via WhatsApp.
2. **Operadores / atendentes** — funcionários ou PJ da empresa-cliente que usam o CRM.
3. **Titulares de dados sensíveis (condicional)** — quando o tenant é clínica médica, dados de saúde podem aparecer no conteúdo de mensagens e em `wa_contacts.notes`.

## 1.3 Categorias de dados pessoais tratados

| Categoria | Campos / origem | Sensível? |
|---|---|---|
| Identificadores de contato | `wa_contacts.wa_id` (telefone), `phone_formatted`, `display_name`, `declared_name`, `whatsapp_profile_name` | Não (telefone = pessoal, alto risco de identificação) |
| Imagem | `wa_contacts.profile_picture_url`, `contact_avatar_path` | Não (potencialmente biométrico se foto de rosto) |
| Conteúdo de comunicação | `wa_messages.content`, `media_path`, `transcription`, `reply_to_preview` | Pode conter sensível conforme tenant |
| Geolocalização | `wa_messages.latitude` / `longitude` (mensagens de localização) | Comportamental — alto risco |
| Notas e qualificação | `wa_contacts.notes`, `qualification`, `rating` | Pode conter sensível (clínica) |
| Identidade do operador | `users.username`, `display_name`, `email`, `firebase_uid`, `avatar_path`, `password_hash` | Não (`password_hash` = credencial) |
| Dados comportamentais do operador | `users.last_login`, `audit_log.ip_address`, contadores de tentativas | Não |
| Credenciais de canal | `channels.access_token`, `token_expires_at` (não é dado pessoal de titular, mas segredo crítico) | Credencial |
| Dados sensíveis (art. 11) | Saúde, em tenants de clínica — texto livre de mensagens / `notes` | **Sim** |
| Estado e ciclo de vida do atendimento *(Fase 4)* | `wa_conversations.attendance_status` (`aberto`/`fechado_inatividade`/`fechado_manual`), `assigned_to`, `takeover_status`, `takeover_handler_user_id`, `lead_owner_user_id` | Não (metadado operacional) |
| Protocolo de atendimento diário *(Fase 5A)* | `attendances_daily/{id}` (`id=YYYYMMDD-{contact_id}-{SETOR}`, `status`, `protocolo_informado`, `criado_em`, `ultima_interacao`, `fechado_em`, `fechado_por_user_id`) + `wa_messages.protocol_id` (denorm) | Não (metadado; é o "carimbo" do dia que o cliente recebe ao fechar) |
| Conteúdo de comunicação interna *(Modo 1 — Sussurro)* | `wa_messages` com `direction="internal"` e `msg_type="internal"` — anotação operador→operador/supervisor; **não vai pra Meta** | Pode conter sensível indireto (orientação sobre o caso/cliente) |
| Atribuição dupla supervisor *(Modo 2 — Co-pilotagem)* | `wa_messages` outbound com `sender_user_id` ≠ `channel_owner_user_id` + prepend `[Supervisao - nome]:` no texto | Não (rastreabilidade de autoria) |

Legenda de base legal: **7º-V** = execução de contrato/procedimentos preliminares; **7º-IX** = legítimo interesse (com teste de proporcionalidade); **7º-I / 8º** = consentimento; **7º-II** = cumprimento de obrigação legal; **11** = dado sensível (consentimento específico destacado ou tutela da saúde — art. 11, II, "f"). A **definição da base legal cabe ao controlador**; as indicações abaixo são as aplicáveis ao desenho técnico.

| # | Operação | Finalidade | Base legal aplicável | Titulares | Dados | Compartilhamento / destinatários | Transf. internac |
|---|---|---|---|---|---|---|---|
| 1 | **Recepção de mensagens inbound** | Receber e registrar a comunicação iniciada pelo titular para atendimento | 7º-V; 11 se clínica | Cliente final | Telefone, nome de perfil, conteúdo, mídia, localização | Meta (origem), Google Firestore (armazenamento) | **Sim** — M (EUA) |

| # | Operação | Finalidade | Base legal aplicável | Titulares | Dados | Compartilhamento / destinatários | Transf. internac |
|---|---|---|---|---|---|---|---|
| 2 | **Envio de mensagens outbound** | Responder o titular dentro do atendimento | 7º-V | Cliente final | Telefone, conteúdo, mídia | Meta (entrega) | **Sim** — M (EUA) |
| 3 | **Gestão e qualificação de contatos (CRM)** | Organizar, qualificar e atribuir o lead ao operador | 7º-IX (legítimo interesse do controlador) | Cliente final | Nome declarado, `notes`, `qualification`, `rating`, atribuição | Google Firestore | Não (dac no Brasil) |
| 4 | **Mídia e localização** | Armazenar anexos e localização trocados na conversa | 7º-V | Cliente final | Imagem/áudio/vídeo/documento, lat/long | Google Cloud Storage **ou** Firestore (config `MEDIA_STORAGE_BACKEND`) | **A verific** (região d bucket G |
| 5 | **Transcrição de áudio** | Converter áudio recebido em texto para o operador | 7º-V | Cliente final | Conteúdo de áudio → `transcription` | **Nenhum terceiro** — faster-whisper roda **localmente no Cloud Run** | Não |
| 6 | **Onboarding de canal (Embedded Signup)** | Vincular o número WhatsApp do controlador/operador ao CRM | 7º-V | Operador (owner do canal) | `owner_user_id`, `owner_firebase_uid`, `display_phone_number`, token | Meta (OAuth/Graph) | **Sim** — M (EUA) |
| 7 | **Autenticação e gestão de operadores** | Autenticar e autorizar o acesso do operador ao CRM | 7º-V (contrato de trabalho/PJ); 7º-IX (segurança) | Operador | E-mail, nome, `firebase_uid`, `password_hash`, `last_login`, IP | Google Firebase Auth | **Sim** — Google (entidade |
| 8 | **Auditoria** | Registrar quem fez o quê (responsabilização — art. 6º X) | 7º-II / 7º-IX | Operador | `user_id`, `action`, `detail`, `ip_address` | Google Firestore | Não (Bra |
| 9 | **Roteamento multi-tenant** | Resolver o tenant correto a partir do `phone_number_id` do webhook | 7º-V | — (índice técnico) | `phone_number_id` → `tenant_id`, `channel_id` | Google Firestore | Não (Bra |
| 10 | **Comunicação interna (condicional)** | Comunicação operacional entre operadores | 7º-IX | Operador | E-mail, nome, conteúdo de mensagem interna | Google (Chat) | **Sim** — Google ( se habilit |
| 11 | **Ciclo de vida do atendimento (auto-close)** *(Fase 4)* | Sinalizar "atendimento concluído" sem dependência exclusiva da ação humana — higiene operacional e gatilho do recibo do dia | 7º-IX (legítimo interesse do controlador) | Cliente final / Operador | `wa_conversations.attendance_status`, `last_message_at`, `assigned_to` | Google Firestore (Brasil) | Não |
| 12 | **Protocolo do dia + envio automático ao cliente** *(Fase 5A)* | Gerar identificador único por (Lead, dia) e enviar ao cliente como "recibo" no fechamento (manual ou auto-close) | 7º-V (execução do atendimento) | Cliente final | `attendances_daily/*` + `wa_messages.protocol_id` (denorm) + mensagem outbound `"Seu protocolo de hoje é {id}..."` | Meta (entrega ao cliente quando ≤24h), Google Firestore (armazenamento) | **Sim** — M (EUA) somente entrega d frase |
| 13 | **Intervenção do supervisor (3 modos)** *(Fase 3)* | Permitir orientar (Sussurro), responder ao lead sem assumir (Co-pilotagem assinada) e assumir thread (Takeover) com auditoria explícita | 7º-IX | Cliente final / Operador / Supervisor | (Sussurro) `wa_messages` `direction="internal"` — sem ir pra Meta; (Co-pilotagem) `wa_messages` outbound com `sender_user_id`=supervisor + texto com prepend `[Supervisao - nome]:`; (Takeover) mudança de `wa_conversations.assigned_to` + mensagem automática ao lead se ≤24h | Meta (modos 2 e 3 quando há entrega ao lead) | **Sim** — M (EUA) no modos 2 |
| 14 | **Painel de Conflitos (admin/supervisor)** | Dar ao supervisor visão dos Leads | 7º-IX | Cliente final / | Agregação read-only sobre `wa_conversations` (`assigned_to`, | Google Firestore (Brasil) | Não |

| # | Operação | Finalidade | Base legal aplicável | Titulares | Dados | Compartilhamento / destinatários | Transf. internac |
|---|---|---|---|---|---|---|---|
| | *(Fase 3A)* | tocados por ≥2 operadores em paralelo (gestão de equipe + LGPD: detectar acesso cross-operador inadvertido) | | Operador | `channel_active`, `last_message_at`) + join com contato | | |

# PARTE 2 — RIPD (Relatório de Impacto à Proteção de Dados)

> Art. 5º XVII e art. 38 da LGPD. Este RIPD avalia riscos do tratamento aos direitos e liberdades dos titulares e descreve as medidas de mitigação. Como a Castro atua como operadora, o RIPD serve de **insumo técnico ao controlador** e de base ao plano de adequação interno.

## 2.1 Descrição e finalidade do tratamento

O sistema recebe, armazena e permite responder conversas de WhatsApp entre clientes finais e operadores das empresas-clientes, com camada de CRM (qualificação de lead, atribuição, transferência entre operadores, métricas). Finalidade central: **viabilizar e organizar o atendimento que o próprio titular iniciou** com a empresa-cliente.

## 2.2 Necessidade e proporcionalidade

- O dado mínimo para a finalidade (telefone + conteúdo da conversa) é intrínseco ao canal WhatsApp — coleta proporcional.
- Campos de CRM (`notes`, `qualification`, `rating`) excedem o mínimo do canal e dependem de **legítimo interesse do controlador com teste de proporcionalidade documentado** — responsabilidade do controlador.
- O `state_sync` cria contatos sem conversa para não poluir a lista; reduz exposição desnecessária, mas ingere números da agenda do operador — atenção a proporcionalidade (ver risco R-13).
- **Gap de minimização:** geolocalização (`latitude`/`longitude`) é armazenada em precisão total sem necessidade declarada (R-1 da tabela §2.4).

## 2.3 Partes interessadas e fluxos

Ver **Parte 3 — Mapa de suboperações e fluxo de dados**.

## 2.4 Inventário de riscos aos titulares

Escala: Gravidade (Baixa/Média/Alta) × Probabilidade (Baixa/Média/Alta) → Prioridade. Esforço de mitigação (Baixo/Médio/Alto).

| ID | Risco | Artigo LGPD | Origem | Gravidade | Prob. | Esforço | Prioridade |
|---|---|---|---|---|---|---|---|
| R-1 | **Identidade do remetente em canal coex compartilhado** — cliente recebe do número pessoal do owner, mas quem responde é outro operador; expectativa falsa de pessoalidade | art. 6º VI (boa-fé/transparência) | ADR 0002 #1 | Média | Alta | Baixo | **Alta** |
| R-2 | **Acesso ao histórico após transferência** — operador B lê tudo que o titular confiou ao operador A | art. 6º I (finalidade) | ADR 0002 #2 | Média | Alta | Médio (jurídico) | **Alta** |
| R-3 | **Número pessoal como ferramenta** — no desligamento o chip/app sai com o operador, controlador perde controle de dados de titulares | art. 6º VII/X | ADR 0002 #3 | Alta | Média | Médio (jurídico/RH) | **Alta** |
| R-4 | **Audit de leitura passiva incompleto** — snapshot Firestore vai client→Firestore direto, não gera `audit_log`; "quem leu" não é demonstrável | art. 6º X (responsabilização) | ADR 0002 #4 | Média | Alta | Baixo-Médio | Média |
| R-5 | **Embedded Signup duplicado** sobrescreve `phone_routing`; mensagens ficam atribuídas ao operador errado, auditoria fica inconsistente | art. 6º X | ADR 0001 | Alta | Baixa | Baixo | **Alta** |
| R-6 | **Firestore rules permissivas em produção** — gate por whitelist de e-mail, não por isolamento de tenant via claim; regras estritas estão em WIP | art. 6º VII/IX, art. 47 | `firestore.rules`, `firestore-rules-staging-strict.wip` | Alta | Média | Alto | **Alta** |
| R-7 | **Sem endpoints de direitos do titular** — não há acesso/correção/eliminação/portabilidade programáticos | art. 18 | Mapeamento (ausente) | Alta | Alta | Alto | **Alta** |
| R-8 | **Sem política formal de retenção/expurgo** — soft-delete só arquiva; dados retidos indefinidamente | art. 15/16 | Mapeamento (ausente) | Média | Alta | Médio | **Alta** |

| ID | Risco | Artigo LGPD | Origem | Gravidade | Prob. | Esforço | Prioridade |
|---|---|---|---|---|---|---|---|
| R-9 | **PII em logs** — `pii_redaction.py` existe mas não é aplicado universalmente | art. 6º VII, art. 46 | `pii_redaction.py` + revisão pendente | Média | Média | Médio | Média |
| R-10 | **Sem criptografia de campo para dado sensível** — exigida pelo `CLAUDE.md §2` em cenário clínica; hoje só encriptação default do Firestore | art. 11, art. 46 | `CLAUDE.md §2` (não implementado) | Alta (clínica) | Média | Alto | **Alta** se onboardar clínica |
| R-11 | **DPA / garantias de transferência internacional não verificados** com Meta e Google | art. 28, 33, 39 | Mapeamento (não verificado) | Alta | Alta | Médio (jurídico) | **Alta** |
| R-12 | **Região do bucket GCS de mídia não verificada** — possível residência fora do Brasil | art. 33 | Mapeamento (não verificado) | Média | Média | Baixo | **Alta** (fácil de fechar) |
| R-13 | **Consentimento não capturado de forma explícita/rastreável** | art. 7º/8º | Mapeamento (ausente) | Média | Alta | Médio | Média (depende da base legal escolhida pelo controlador) |

### 2.5 Medidas de mitigação já existentes (pontos fortes)

- **Isolamento multi-tenant estrutural** — subcoleções `tenants/{tenant_id}/...` (`CLAUDE.md §4`, `firestore_common.py`), não apenas filtro lógico.
- **Validação HMAC-SHA256 do webhook** antes de processar payload Meta (`webhook.py`).
- **Firebase Auth + gate de e-mail/domínio** + custom claims `tenant_id`/`role` (`auth.py`).
- **`audit_log` de mutações** com `user_id`, `action`, `detail`, `ip_address` (`database_firestore.py`).
- **Utilitários de redação de PII** — `redact_phone`/`redact_name`/ `redact_secret` (`pii_redaction.py`).
- **Dados primários no Brasil** — Firestore + Cloud Run em `southamerica-east1`.
- **Auditoria de campo duplo** — `channel_owner_user_id` vs `sender_user_id` permite rastrear quem digitou mesmo em canal coex (`CLAUDE.md §4`).
- **Soft-delete** — contatos arquivados, recuperáveis por admin.

### 2.6 Risco residual

Com as medidas atuais, o risco residual é **MÉDIO-ALTO**, concentrado em: (a) direitos do titular não operacionalizáveis sem processo manual (R-7); (b) governança de retenção e transferência internacional não formalizada (R-8, R-11, R-12); (c) modelo coex compartilhado exige instrumentos jurídicos do controlador (R-1, R-2, R-3). Após o plano de adequação da §7, o risco residual projetado é **BAIXO-MÉDIO**.

### 2.7 Conclusão / opinião do encarregado

`[ENCARREGADO_CASTRO]`: o tratamento é **necessário e proporcional à finalidade de atendimento**, com arquitetura de segurança sólida na base, mas **não deve onboardar tenant com dados sensíveis (clínica médica) antes de fechar R-10 e R-6**, e **não deve escalar o modelo coex compartilhado para clientes #2+ antes de R-1, R-2 e R-3** (alinhado com ADR 0002, itens 3a/3b como pré-requisitos jurídicos). Direitos do titular (R-7) devem ser garantidos por procedimento manual documentado enquanto os endpoints não existem.

---

## PARTE 3 — Mapa de suboperações e fluxo de dados

### 3.1 Suboperador: Firebase (Google)

| Serviço | Uso | Dado pessoal envolvido | Localização |
|---|---|---|---|
| **Cloud Firestore** | Banco primário (contatos, mensagens, usuários, canais, auditoria) | Todos os dados pessoais do produto | `southamerica-east1` (Brasil) |
| **Firebase Auth** | Identidade do operador, verificação de ID token, custom claims `tenant_id`/`role` | E-mail, `firebase_uid` | Serviço Google (entidade US) |
| **Cloud Storage (Firebase)** | Armazenamento de mídia (condicional ao `MEDIA_STORAGE_BACKEND`) | Imagem/áudio/vídeo/documento | **Região a verificar** |
| Hosting / FCM / Functions | **Não utilizados** | — | — |

### 3.2 Suboperador: Google Cloud Platform (GCP)

| Serviço | Uso | Dado pessoal | Localização |
|---|---|---|---|
| **Cloud Run** | Backend FastAPI + frontend (`castro-crm`, `castro-crm-staging`, projeto `project-26fb9c99-8ee9-4179-aef`) | Processa todos em trânsito | `southamerica-east1` (Brasil) |
| **Cloud Storage** | Mídia (`GCS_MEDIA_BUCKET`/`GCS_MEDIA_PREFIX`) | Anexos das conversas | **A verificar** (R-12) |
| **Secret Manager** | Tokens WhatsApp, `WHATSAPP_APP_SECRET`, segredos de cron | Não é dado de titular (segredo) | Serviço **global** |

| Serviço | Uso | Dado pessoal | Localização |
|---|---|---|---|
| **Cloud Logging** | Logs de aplicação | PII se não redigida (R-9) | `southamerica-east1` |

## 3.3 Suboperador: Meta / WhatsApp

| Interface | Uso | Dado pessoal | Fronteira |
|---|---|---|---|
| **Webhook inbound** | Recebe mensagens, status, eventos de conta; validado por HMAC-SHA256 | Telefone, nome, conteúdo, mídia, localização | Meta → Brasil (entrada) |
| **Graph API v22.0 (`graph.facebook.com`)** | Envio outbound, upload de mídia, descoberta de número/WABA | Telefone, conteúdo, mídia | Brasil → Meta (**EUA**) |
| **Embedded Signup** | Onboarding de canal (coexistence/standard), troca de token OAuth | Identidade do owner, número, token | Brasil → Meta (**EUA**) |

Castro Intelligence é **Tech Provider verificado** (Business ID `877897608035564`, App ID `1434723791183375`). Modelo financeiro passthrough: o cliente é dono da WABA e paga a Meta diretamente (`CLAUDE.md §1`).

## 3.4 Diagramas de fluxo

(i) Inbound — cliente → Meta → CRM

```
Cliente WhatsApp
   │  mensagem
   ▼
Meta Cloud API (EUA) ──webhook HTTPS──▶ Cloud Run /webhook (BR)
                                          │ valida HMAC-SHA256
                                          │ phone_routing[phone_number_id] → tenant_id
                                          │ set_tenant_context(tenant_id)
                                          ▼
                                    Firestore (BR)
                                      wa_contacts / wa_conversations / wa_messages
                                          │ (download de mídia → GCS/Firestore)
                                          ▼
                                    Operador (snapshot Firestore — NÃO passa pelo backend → não gera audit_log, ver R-4)
```

(ii) Outbound — operador → cliente

```
Operador (frontend) ──ID token Firebase──▶ Cloud Run /api/wa/send* (BR)
   │ verify_id_token → tenant_id + operator_id
   │ resolve credenciais do canal (token, phone_number_id)
   │ _check_24h_window
   ▼
Graph API v22.0 (EUA)  ──────────────────▶ Cliente WhatsApp
   │ resposta
   ▼
Firestore (BR): save_wa_message (sender_user_id, channel_owner_user_id)
   + log_audit(WA_SEND)   ←── FRONTEIRA: dado cruza para Meta (EUA)
```

(iii) Transferência de thread entre operadores

```
Operador A ──/api/wa/transfer──▶ Cloud Run (BR)
   │ valida autorização (admin/supervisor/assigned)
   │ atualiza conversation.assigned_to(_uid)
   │ cria wa_transfer_log + mensagem de sistema
   │ log_audit(TRANSFER)
   ▼
Operador B passa a ver a thread (e todo o histórico anterior → ver R-2)
```

(iv) Mídia

```
Upload do operador ──/api/wa/send-media──▶ Cloud Run (BR)
   │ valida MIME/tamanho
   ▼
MEDIA_STORAGE_BACKEND ∈ { local | GCS (região? R-12) | Firestore chunked }
   ▼
upload p/ Meta /media (EUA) → media_id → envia mensagem
```

(v) Transcrição de áudio (sem terceiro)

```
Áudio inbound ──▶ download ──▶ ffmpeg (ogg/opus) ──▶ faster-whisper
   (modelo pre-embarcado na imagem Docker em build-time, HF_HUB_OFFLINE=1;
    roda localmente no Cloud Run, BR; condicional FEATURE_AUDIO_TRANSCRIPTION)
   ──▶ wa_messages.transcription   ── nenhum dado sai para terceiro
```

Fronteiras de transferência internacional (art. 33)

| Caminho | Suboperador | País | Base de transferência |
|---|---|---|---|
| Conteúdo de mensagens (in/out) | Meta | EUA | **A confirmar** — cláusulas-padrão/garantias adequadas via DPA (R-11) |
| Identidade do operador | Google (Firebase Auth) | Entidade US (dado lógico) | **A confirmar** DPA Google (R-11) |
| Segredos | Google Secret Manager | Serviço global | Não é dado de titular; acesso só do Cloud Run (BR) |
| Dados primários (Firestore, Cloud Run, Logging) | Google | **Brasil** (`southamerica-east1`) | Sem transferência internacional |
| Mídia (GCS) | Google | **A verificar** | R-12 |

# §6 — Lista consolidada de gaps (uso interno)

| ID | Gap | Severidade | Esforço | Referência de código |
|---|---|---|---|---|
| R-7 | Sem endpoints art. 18 (acesso/correção/eliminação/portabilidade) | Alta | Alto | ausente; ADR 0002 propõe `GET /api/admin/lgpd/access-report` |
| R-6 | Firestore rules permissivas em prod | Alta | Alto | `firestore.rules`, `docs/internal/firestore-rules-staging-strict.wip` |
| R-11 | DPA/transferência internacional não verificada | Alta | Médio | contratual (Meta/Google) |
| R-10 | Sem criptografia de campo p/ sensível | Alta (clínica) | Alto | `CLAUDE.md §2` (requisito não implementado) |
| R-5 | Embedded Signup duplicado | Alta | Baixo | `main.py embedded_signup_exchange`; ADR 0001 |
| R-8 | Sem política de retenção/expurgo | Média | Médio | soft-delete em `database_firestore.py` (só `is_archived`) |
| R-12 | Região do bucket GCS não verificada | Média | Baixo | `media.py` / `GCS_MEDIA_BUCKET` |
| R-1 | Identidade do remetente coex | Média | Baixo | `main.py wa_send`; ADR 0002 #1 |
| R-2 | Histórico pós-transferência | Média | Médio (jurídico) | `_check_conv_send_permission`; ADR 0002 #2 |
| R-3 | Número pessoal como ferramenta | Alta | Médio (jurídico/RH) | ADR 0002 #3 |
| R-4 | Audit de leitura passiva | Média | Baixo-Médio | snapshot Firestore; ADR 0002 #4 |
| R-9 | PII em logs | Média | Médio | `pii_redaction.py` (aplicação parcial) |
| R-13 | Consentimento não rastreável | Média | Médio | ausente |

# §7 — Plano de adequação priorizado

Reaproveita a priorização do ADR 0002 e acrescenta os itens de governança identificados no mapeamento. Ordem sugerida por gravidade × esforço.

Onda 1 — quick wins de alto valor (esforço baixo)

| Ação | Fecha | Esforço | Dono |
|---|---|---|---|
| Verificar e, se preciso, recriar bucket GCS de mídia em `southamerica-east1` | R-12 | Baixo | Eng/Infra |
| Checagem de duplicata em `embedded_signup_exchange` → HTTP 409 (ADR 0001) | R-5 | Baixo | Eng |
| Assinatura automática `— {nome}, equipe {tenant}` quando `sender != owner` (ADR 0002 #1) | R-1 | Baixo | Eng |
| Mensagem de sistema visível ao cliente em transferência humano↔humano (ADR 0002 #2) | R-2 (parcial) | Baixo | Eng |

Onda 2 — governança jurídica (pré-requisito p/ escalar)

| Ação | Fecha | Esforço | Dono |
|---|---|---|---|
| Confirmar/assinar DPA + garantias de transf. internacional com Google e Meta | R-11 | Médio | Jurídico |
| Política de privacidade do controlador declarando atendimento em equipe (ADR 0002 #3a) | R-2/R-3 | Médio | Jurídico (cliente) |
| Cláusula contratual: número coex = ferramenta de trabalho, devolução no desligamento (ADR 0002 #3b) | R-3 | Médio | Jurídico/RH (cliente) |
| Definir e publicar encarregado (DPO) da Castro + canal do titular | governança | Baixo | Castro |
| Definir base legal por operação com o controlador + registro de consentimento quando aplicável | R-13 | Médio | Jurídico + Eng |

Onda 3 — direitos do titular e retenção (esforço alto)

| Ação | Fecha | Esforço | Dono |
|---|---|---|---|
| Endpoint `GET /api/admin/lgpd/access-report?wa_id=` (acesso/portabilidade — ADR 0002 #6) | R-7 | Alto | Eng |
| Endpoints de correção / anonimização / eliminação definitiva (além do soft-delete) | R-7 | Alto | Eng |
| Política de retenção + job de expurgo (Cloud Scheduler) por categoria | R-8 | Médio | Eng |
| Procedimento manual documentado de resposta a titular (ponte enquanto endpoints não existem) | R-7 | Baixo | Castro/DPO |

Onda 4 — hardening estrutural

| Ação | Fecha | Esforço | Dono |
|---|---|---|---|
| Firestore rules estritas por `tenant_id`/`assigned_to` (retomar WIP) | R-6 | Alto | Eng |
| Audit de leitura via heartbeat `POST /api/wa/conversation/{id}/opened` (ADR 0002 #4) | R-4 | Baixo-Médio | Eng |
| Criptografia de campo para dados sensíveis (pré-requisito p/ onboardar clínica) | R-10 | Alto | Eng |
| Auditoria LGPD dos logs + aplicação universal de `pii_redaction` | R-9 | Médio | Eng |

**Marcos bloqueantes:**

- Onboardar **clínica médica** → exige Onda 4 (R-10, R-6) concluída.
- Escalar **coex compartilhado p/ cliente #2+** → exige Onda 2 (R-2/R-3) + Onda 1 (R-1) concluídas (alinhado ao ADR 0002).

---

## Checklist de cobertura deste documento

- [x] **RoPA** — Parte 1 (agentes, titulares, categorias de dados, 10 operações)
- [x] **RIPD** — Parte 2 (descrição, necessidade, riscos R-1..R-13, mitigações, risco residual, conclusão)
- [x] **Mapa de suboperações + fluxo de dados** — Parte 3 (Firebase, GCP, Meta; 5 diagramas; fronteiras de transf. internacional)
- [x] Diagnóstico honesto + gaps (§6) + plano de adequação priorizado (§7)

## Pendências externas (não bloqueiam este documento)

1. Região efetiva do bucket GCS de mídia — verificar via `gsutil` / console (R-12).
2. Existência e escopo do DPA assinado com Google e com Meta (R-11).
3. Dados cadastrais e encarregado de cada cliente controlador (`[CONTROLADOR_*]`, `[ENCARREGADO_CLIENTE]`).
4. Nomeação formal do encarregado (DPO) da Castro (`[ENCARREGADO_CASTRO]`).